



Product Security

Product Security’s mission is to set the standard for product security by fostering a culture of rapid innovation and secure product delivery. We are committed to leveraging the GitLab platform, embodying the pinnacle of internal usage (‘dogfooding’) practices.

Aligned with GitLab’s overarching information security strategy and its three-year plan, the Product Security Department (PSD) within the Security Division is responsible for crafting and directing a comprehensive vision to bolster the cybersecurity posture of the GitLab platform.

What is Product Security at GitLab?

At GitLab, product security encompasses a broad range of cybersecurity disciplines that enable product and engineering teams to design, develop, deploy, maintain, and refine GitLab’s technologies securely. This goes beyond the conventional confines of security, covering everything from protecting developer workstations to ensuring the integrity of our production environments.

Teams

The Product Security sub-department includes the following teams. Learn more about each by visiting their handbook pages.

Sub-department	When to reach out	Teams
Security Platforms & Architecture (SPA)	If you’re building features or AI capabilities	SPA , AppSec
Infrastructure Security (InfraSec)	If you’re working on infrastructure	InfraSec , Data Security
Security Capabilities Engineering (SCE)	If you’re working around vulnerability data, bug bounty, or security tooling	Vuln MGMT , PSIRT , ProdSecEng

The Product Security Mission

Our mission is to set the standard for product security by fostering a culture of rapid innovation and secure product delivery. We are committed to leveraging the GitLab platform, embodying the pinnacle of internal usage ('dogfooding') practices. By maintaining close collaboration with product teams and contributing significant security features and capabilities to the GitLab codebase, we aim to enhance our operations and be a vital driver of the broader GitLab vision.

Multi-Year Product Security Mission

Our comprehensive, [multi-year product security mission](#) can be found in our internal handbook.

Product Security Risk Register

Our Product Security Risk Register process details can be consulted on [this dedicated page](#).

Collaboration is Key

Success in product security is not confined to PSD or even the Security Division. It requires a concerted effort across the entire GitLab ecosystem. Collaboration is crucial, involving not just our security counterparts but the broader organization. Key disciplines and capabilities, from Security Operations to Site Reliability Engineering, while not directly under PSD's purview, are vital to our strategy's success.

Guiding Principles

- **Business Enablement:** PSD's role is to facilitate GitLab in achieving its business goals by ensuring product teams can operate both efficiently and securely, bolstering customer trust, and utilizing transparency as a strategic advantage. This includes providing insightful product feedback through extensive dogfooding.
- **Empathy and Accessibility:** Recognizing that the optimal security solution may not always align with business or customer needs, PSD prioritizes understanding and empathizing with these unique perspectives. This empathetic approach guides our security practices and engagements, aiming to align our methods with the preferences of our customers and internal teams.
- **Pragmatism Over Perfection:** Addressing current challenges quickly and effectively is preferred over waiting for a perfect solution. PSD focuses on

delivering incremental, tangible value through rapid, short-cycle initiatives, aiming for partial solutions that immediately benefit our long-term goals.

- **Design for Rapid Iteration:** Our strategy and roadmaps are crafted to quickly identify and learn from suboptimal decisions by engaging with customers and stakeholders early and maintaining a tight feedback loop. This approach helps us adapt and refine our strategies and approaches efficiently.
- **Data-Driven Decision Making:** Data drives our objectives, priorities, and actions, reducing the risk of failure or scope creep. Example useful metrics include root cause analyses of incidents (data within), threat modeling outcomes, and production readiness assessments, among others.
- **Scalability and Repetition:** PSD emphasizes scalable, repeatable processes over bespoke solutions, ensuring we can meet growing demands without proportional increases in resources.
- **Decentralization and Empowerment:** Acknowledging that product and engineering teams possess deep, specialized knowledge of their domains, PSD advocates for these teams to take ownership of security tasks like secure code reviews and threat modeling. This decentralization fosters a more integrated and effective security posture across GitLab.
- **Integration with Reliability, Quality, Infrastructure, and Platform Engineering:** PSD's mission to mitigate product security flaws is inherently tied to improving overall product quality and reliability. We aim to leverage and integrate with the practices of existing teams to enhance both security and product excellence.

Product Security Department Label Standardization

The Product Security Department has standardized its labeling system to improve issue tracking, team identification, and cross-team collaboration across all security teams.

Mandatory Division and Department Labels

All issues, epics, and merge requests within the Product Security Department must include the **"Division::Security"** and **"Department::Product Security"** labels.

Team-Specific Labels

Each team uses a standardized naming convention :

- **Application Security:** ~"Application Security Team"
- **Infrastructure Security:** ~"Infrastructure Security Team"

- **Data Security:** ~“Data Security Team”
- **Vulnerability Management:** ~“Vulnerability Management Team”
- **Product Security Engineering:** ~“Product Security Engineering”
- **Security Platforms & Architecture:** ~“Security-Platforms-Architecture Team”
- **Security Research:** ~“Security Research Team”
- **Security Architecture:** ~“Security Architecture Team”

Multiple team labels can be applied to issues requiring collaboration

[Data Security](#)

GitLab's Data Security team investigates and remediates known unknowns in our data security and privacy posture.

[Infrastructure Security](#)

GitLab's Infrastructure Security provides security oversight of the SaaS.

[Product Security Incident Response Team \(PSIRT\)](#)

PSIRT home page

[Security Capabilities Engineering](#)

Security Capabilities Engineering Team Charter

[Security Platforms & Architecture](#)

Security Platforms & Architecture Team Charter

[Security Review Framework](#)

GitLab Security Review Framework (SRF) helps to prioritize features for security review and decides which teams need to be engaged in the security review along with the type of review that needs to be conducted.

[Supply Chain Risk Management Strategy](#)

This page outlines GitLab's comprehensive approach to supply chain risk management, providing a structured framework for identifying, assessing, and mitigating risks across the software development lifecycle while advancing toward higher SLSA compliance levels.

[Vulnerability Management](#)

Visibility: Audit Vulnerability Management is the continual process of identifying, prioritizing, ...

[Vulnerability Triage](#)

Purpose and Overview This runbook describes the process for triaging issues labeled ...

Last modified March 2, 2026: [Add "When to reach out" guidance to Product Security Teams table \(2de5c214\)](#).

 [View page source](#) -  [Edit this page](#) - please [contribute](#). 